

TURRET OS: Multi-Layered Graph and Rule-AST Architecture Rescuing Insider Threat Detection Against Out-of-Distribution Adversaries

Ali Hamza^{a,*}, Ghulam Mujtaba^b

^aNational University of Sciences and Technology (NUST), Islamabad, Pakistan

^bNational University of Computer and Emerging Sciences (FAST-NUCES), Islamabad, Pakistan

ARTICLE INFO

ABSTRACT

Keywords:

Insider Threat Detection

Provenance Knowledge Graphs

Graph Neural Networks

Digital Forensic Readiness

ISO/IEC 27043

Male Users

Out-of-Distribution Evasion

1. Introduction
Insider incidents—abuse of authorised access by legitimate users—continue to be a leading operational, financial, and regulatory exposure for enterprise security programmes. The dominant defensive response today is machine-learning detection over user-behaviour features, file-system telemetry, and provenance graphs; however, when reduced to a single feature layer, these detectors degrade sharply under out-of-distribution adversarial adjustment, and their alert outputs rarely satisfy courtroom admissibility standards. This paper addresses two open problems in tandem: detector resilience under held-out out-of-distribution adversaries, and a continuous inference-to-evidence chain that delivers forensically admissible artefacts.

Prior research clusters in four strands. The first applies graph-neural architectures to multi-modal insider telemetry—SENTINEL [Xiao et al., 2024], DTGI [Gao et al., 2023], MEWRGNN [Xiao et al., 2022], and TGCN-DA [Li et al., 2023]—alongside feature-engineered baselines including Le and Zincir-Heywood [Le et al., 2020] and E-Watcher [Wei et al., 2024]. The second strand builds provenance-graph cybersecurity for tactical attack attribution—CSKG4APT [Ren et al., 2022], KRYSTAL [Kurniawan et al., 2022], KGRAG [Aki et al., 2025], and the provenance-graph survey of Li et al. [Li et al., 2021]—but typically terminates outputs at alert generation. The third strand extracts file-metadata signals: image-EXIF vectorisation in Exif2Vec [Umair et al., 2024] and Yasenenko [Yasenenko, 2025], and OOXML-revision and tamper forensics in Didriksen [Didriksen, 2014] and Fu et al. [Fu et al., 2015]. The fourth strand formalises digital forensic readiness under ISO/IEC 27043 for SaaS insider threats [Shoderu et al., 2025, 2026] and grounds provenance representation in W3C PROV [Yusof et al., 2025, Sikos and Philp, 2020] and operational trace frameworks [Garfinkel et al., 2013].

Several gaps remain. (i) Published detectors are predominantly single-layer—feature-engineered pipelines, monolithic graph neural networks, or stand-alone rule engines—and degrade sharply when faced with out-of-distribution adversaries whose observable features converge with benign

baseline traffic [Wei et al., 2024, Xiao et al., 2024, Gao et al., 2023]. (ii) File-metadata work remains narrowly restricted to image EXIF; cross-format provenance covering OOXML revisions, DWG authorship, EML headers, and git commit chains is absent [Umair et al., 2024, Yasenenko, 2025, Didriksen, 2014, Fu et al., 2015]. (iii) Provenance-graph research emits alerts but rarely couples them to W3C-PROV-aligned evidence chains suitable for forensic-readiness audits [Ren et al., 2022, Kurniawan et al., 2022, Aki et al., 2025, Li et al., 2021]. (iv) Readiness frameworks under ISO/IEC 27043 target SaaS-cloud deployments and have not been extended to on-premise or hybrid enterprise environments [Shoderu et al., 2025, 2026]. (v) No prior system braids multi-layer inference, cross-format metadata extraction, and court-grade evidence delivery in a single architecture.

Against these gaps we propose TURRET OS,¹ a four-layer architecture that fuses a cross-format metadata-harvest layer (L1), a Neo4j knowledge-graph layer (L2), a rule-AST inference layer (L3), and a multi-layer GraphSAGE inference layer (L3.5) into one calibrated decision surface; a fourth layer emits W3C-PROV-grounded, Merkle-chain-integrity-protected, Ed25519-signed evidence packs aligned to all eight ISO/IEC 27043 readiness attributes—Identification, Collection, Acquisition, Preservation, Analysis, Presentation, Chain of Custody, and Integrity Verification. Under an out-of-distribution credential-phishing adversary the multi-layer stack retains AUC 0.9572 with only a 4.12% drop, while single-layer feature detectors collapse to AUC 0.7363 with a 26.25% drop—a +22.09% architectural rescue. On the D5 Synthetic-Tenant Pilot (35 users, 90 days) with a held-out OOD profile, full-stack detection attains ROC-AUC 0.9928, F1 @ 0.5% FPR of 0.8936, and MCC 0.9539; the top SHAP feature is `copy_to_removable`, an operationally interpretable signal verified by a runtime feature-whitelist invariant that guarantees zero label leakage at deployment. End-to-end ISO/IEC 27043 readiness coverage is verified at 100% across all eight required attributes.

The remainder of the paper is organised as follows. Section 2 reviews prior literature across graph-neural insider detection, provenance-graph cybersecurity, file-metadata

*Corresponding author

ahamza.msse25mcs@student.nust.edu.pk (A. Hamza)

¹Project repository: <https://github.com/ali-Hamza817/Turret-OS>

forensics, and ISO/IEC 27043 readiness. Section 3 specifies the adversary model, attack vectors, and evaluation criteria. Section 4 presents the TURRET OS architecture layer by layer. Section 5 reports the implementation stack on an 80-core, 503.58 GB-RAM, NVIDIA L40S, Python 3.12.9 platform. Section 6 details the experimental evaluation, including baseline comparison, layer ablation study, Pareto PR frontier, single-layer versus multi-layer adversarial robustness, ISO/IEC 27043 coverage, and compute budget. Section 7 discusses architectural and operational implications. Section 8 outlines limitations and future work. Section 9 concludes.

2. Literature Review

Earliest work on insider-threat detection framed the attacker as legitimate trusted credential misuse and pursued identification through hand-crafted rule heuristics and lightweight media forensics. [Garfinkel et al. \[2013\]](#) proposed media-based detection by content-aware fingerprinting and metadata-aware surface analysis of seized artefacts, demonstrating that visible media artefacts alone can discriminate threatening from benign insider behaviour. [Didriksen \[2014\]](#) examined the forensic artefacts of OOXML documents produced by Microsoft Office, showing that revision identity, custom-XML fingerprints, and document-version metadata can be assimilated into identification pipelines for document-level insider analysis. [Fu et al. \[2015\]](#) extended this line by analysing covert channels in Office 2007–2013 documents, demonstrating that XML structure and revision metadata can leak secrets to a co-leaked artefact. Limitations of this early media-only line were threefold: (i) coverage was restricted to a small set of document formats; (ii) operationally deployable detection was not demonstrated; and (iii) no automatic chain of forensic evidence was raised from the artefacts.

The next research wave widened the problem definition and laid the foundations of multi-modal detection and provenance representation. [Mavroeidis et al. \[2018\]](#) introduced a hybrid data-driven physical-security framework merging anomaly detection with user-behaviour profiling, demonstrating improvement of baseline detection on enterprise telemetry. [Le and Zincir-Heywood \[2019\]](#) and [Le et al. \[2020\]](#) systematically compared ensemble-ML and deep-learning approaches across multiple data-granularity levels of CERT insider datasets, with their longitudinal studies reporting machine-learning detection at AUROC 0.92 and F1 0.88 with time-to-detect of 14 minutes. [Homoliak et al. \[2018\]](#) catalogued the taxonomy of insider threats, attack vectors, and defensive controls in their seminal *Insight Into Insiders and IT*, establishing a reference map for the subsequent ML-detection lineage. [Sikos and Philp \[2020\]](#) surveyed provenance-aware knowledge representation models and contextualised knowledge graphs, advancing the formal foundations for representing and reasoning over cyber provenance traces. [Li et al. \[2021\]](#) consolidated system-level provenance-graph survey work for threat detection, establishing that the provenance-graph paradigm is the natural

substrate for post-hoc forensic reasoning over multi-modal telemetry. The limitation of this generation is structural: detection and provenance were treated as separate worlds, no system delivered both with court-grade evidence, and adversarial robustness was not yet measured through held-out attacker profiles.

The third research wave tied provenance-graph analytics to detection of advanced threats and assessed adversarial robustness experimentally. [Ren et al. \[2022\]](#) constructed CSKG4APT—a cybersecurity knowledge graph for advanced persistent threat organisation attribution—by fusing indicators of compromise, threat reports and malware artefacts into a unified graph. [Kurniawan et al. \[2022\]](#) introduced KRYSTAL—a knowledge-graph framework for tactical attack discovery in audit data—demonstrating graph-rule fusion for tactical-stage detection. [Xiao et al. \[2022\]](#) introduced MEWRGNN, a graph-neural-network architecture for anomaly-based insider-threat detection reporting AUROC 0.94 and F1 0.87. [Gao et al. \[2023\]](#) attacked the class-imbalance problem with Deep Temporal Graph Infomax and reported AUROC 0.91 and F1 0.86. [Li et al. \[2023\]](#) proposed TGCN-DA, a temporal graph convolutional network with data augmentation, and reported AUROC 0.95 and F1 0.89. [Xiao et al. \[2024\]](#) advanced the lineage with SENTINEL, a multi-timescale user-behaviour interaction graph learner reporting AUROC 0.93 and F1 0.88. [Wei et al. \[2024\]](#) reported E-Watcher with 98.48% accuracy and 99.23% F1 on CERT r4.2 on a 64 GB MacBook M1 Max platform, securing the most robust reported figures of the lineage but omitting adversarial robustness, cross-format provenance, and forensic-readiness attributes. [Mitra et al. \[2021\]](#) proposed provenance-based counter-measures against fake cyber-threat intelligence, demonstrating that provenance can guard the quality of processed alerts. The limitation of this generation is that detection capability and provenance representation deepened separately; adversarial robustness was not yet measured through held-out attacker profiles, no cross-format file-metadata vector was exploited, and operational evidence chains remained disconnected from ML alerts.

The most recent wave began treating metadata, provenance, and forensic-readiness as first-class research targets. [Umair et al. \[2024\]](#) proposed Exif2Vec, a framework to ascertain untrustworthy crowdsourced images by vectorising EXIF metadata, demonstrating that image-level provenance signals can expose tampering behaviour. [Yasenko \[2025\]](#) evaluated image-recognition systems for automatic detection of malicious files based on image metadata, reporting AUROC 0.76 on a curated image set. [Aki et al. \[2025\]](#) extended KGRAG—provenance-based cyber-threat-intelligence analysis with knowledge graphs and retrieval-augmented generation—pushing provenance representation into LLMs. [Yusof et al. \[2025\]](#) introduced PROVCON, an observability-to-provenance framework, demonstrating that operational telemetry can be elevated to W3C PROV provenance. [Shoderu et al. \[2025\]](#) and [Shoderu et al. \[2026\]](#) formalised digital forensic readiness under ISO/IEC 27043 for

the SaaS-cloud environment, but their evaluation was scoped to SaaS-cloud deployments and did not couple readiness to ML detection or on-premise/hybrid enterprise settings [Shoderu et al., 2025, 2026]. The remaining open gap of this generation is the absence of a unifying architecture that fuses cross-format metadata extraction, multi-layer joint inference, ISO/IEC 27043 readiness, and held-out attacker profiles within a single deployable system.

Synthesising the limitations of the four research waves—narrow format coverage of media forensics, separation of detection and provenance, absence of held-out adversarial regimes, and missing on-premise forensic-readiness coupling—we propose TURRET OS,² a four-layer architecture that fuses cross-format metadata harvest (L1), a Neo4j knowledge graph (L2), a rule-AST inference engine (L3), and multi-layer GraphSAGE inference (L3.5) into one calibrated decision surface; a fourth layer emits W3C-PROV-grounded, Merkle-chained, Ed25519-signed evidence packs aligned to all eight ISO/IEC 27043 readiness attributes. End-to-end detection with the multi-layer stack attains ROC-AUC 0.9997, F1 @ 0.5% FPR of 0.8774, and MCC 0.9770 on the D3 TSEC corpus; under an out-of-distribution credential-phishing adversary the multi-layer stack retains AUC 0.9572 with only 4.12% drop, while single-layer L1 feature detectors collapse to AUC 0.7363 with 26.25% drop—a +22.09% architectural rescue. On the D5 Synthetic-Tenant Pilot (D5, 35 users over 90 days, proactively tagged by Security Operations analysts) with a held-out OOD profile, full-stack detection attains ROC-AUC 0.9928, F1 @ 0.8936, and MCC 0.9539; SHAP feature-importance audit with a runtime whitelist invariant guarantees zero label leakage at deployment, with `copy_to_removable` as the dominant operational signal. ISO/IEC 27043 readiness coverage is verified at 100% across all eight attributes; computational budget is profiled with wall-clock timestamps on an 80-core, 503.58 GB-RAM, NVIDIA L40S, Python 3.12.9 deployment platform. TURRET OS thus closes the four limitations jointly, advancing the state-of-the-art from incremental single-layer detectors to a single deployable braided architecture with court-grade forensic evidence delivery.

3. Threat Model and Problem Formulation

3.1. Adversary Profiles

TURRET OS evaluates adversary profiles across two corpora. On the established CERT-style insider-threat lineage corpus (D3 TSEC) the embedded adversary baseline consists of five synthetic insider scenarios generated over 500 users, 365 days, and 141,657 user-day activity records, with a 1.68% positive rate [Wei et al., 2024, Xiao et al., 2024, Gao et al., 2023]. On the 35-user, 90-day D5 Synthetic-Tenant Pilot (2,431 activity records) a held-out OOD_LAB_EXFILTRATOR profile is injected into the generator without appearing in the training split; this deliberately out-of-distribution scenario functions as a true hold-out evaluation. Across both corpora, four canonical attacker models

anchor the adversarial evaluation track in Table V: Mimicry, Metadata-Strip, Identity-Proxy (GHOST_AUTHOR), and OOD Credential-Phishing. The OOD Credential-Phishing adversary operates during business hours using stolen credentials with low feature novelty, identity-proxy reuse, and removable-media transfers—the regime in which classical novelty-driven insider detectors collapse.

3.2. Attack Vectors and Evasion Strategies

Four evasion strategies are exercised. Mimicry approximates benign-feature distributions to defeat single-layer feature detectors. Metadata-Strip Evasion removes authorship and revision-id signals from OOXML [Didriksen, 2014, Fu et al., 2015], PDF, DWG, EML, git, and image artefacts [Umair et al., 2024, Yassenko, 2025]; this vector specifically targets L1 metadata-only detectors. Identity-Proxy Injection substitutes a clean user's credential surface for the attacker's actions, collapsing naive identity-conditioned rules. OOD Credential-Phishing combines stolen legitimate credentials, business-hours operation, no metadata-stripping, low feature novelty, identity-proxy reuse, and removable-media transfers—the regime in which novelty-, off-hours-, and metadata-driven insider detectors systematically collapse [Ren et al., 2022, Kurniawan et al., 2022]. The four vectors span the limiting cases any deployable insider-threat detector must survive end-to-end.

3.3. Forensic Readiness Requirements

Detection must be coupled to a forensic-evidence chain admissible under ISO/IEC 27043 [Shoderu et al., 2025, 2026]. The architectural target is 100% attribute coverage across the eight mandated attributes: Identification (unique record and alert UUIDs), Collection (documented harvest-pipeline provenance), Acquisition (SHA-256 + BLAKE3 hash verification), Preservation, Analysis (SHAP + GN-Explainer provenance subgraphs), Presentation (analyst-UI workbench export format), Chain of Custody (timestamps and operator-signature tracking), and Integrity Verification (Ed25519 signature over the Merkle root) [Shoderu et al., 2025]. This requirement elevates the threat model from "raise an alert" to "raise an alert admissible as evidence under a forensic readiness audit".

3.4. Detection and Robustness Evaluation Criteria

Detection is reported on three primary metrics: ROC-AUC, F1 @ 0.5% FPR (the precision-critical operating point for low-false-positive deployability), and Matthews Correlation Coefficient (MCC). Calibration is performed via `CalibratedClassifierCV` (isotonic, cv=3); operating thresholds are swept via Youden's J statistic. Target on D3 TSEC: **ROC-AUC 0.9997, F1@0.5%FPR 0.8774, MCC 0.9770**, with the operating threshold pinned at the 0.5% FPR constraint to match the deployment. Target on the D5 OOD_LAB_EXFILTRATOR hold-out: **ROC-AUC 0.9928, F1 0.8936, MCC 0.9539**. Adversarial robustness is bound by **AUC-drop ≤ 5%** against each of the four attacker vectors in §3.2. Cross-layer attribution is bound by a runtime safety invariant: the top-5 SHAP feature importances on the chronological train/test split must

²Project repository: <https://github.com/ali-Hamza817/Turret-OS>

Table 1

Literature Review Summary Table Mapping Key Findings and Structural Limitations Across Prior Work.

Study	Year	Key Findings	Limitations
Didriksen [2014]	2014	Forensic analysis of OOXML artefacts establishing that revision-identity fields, custom-XML fingerprints, and document-version metadata can be assimilated into identification pipelines.	Single document format only; no coupled detection model; no held-out adversary evaluation.
Fu et al. [2015]	2015	Forensic analysis of Microsoft Office 2007–2013 documents demonstrating that XML structure and revision metadata can be exploited; declared useful for covert-channel detection in document artefacts.	Covert-channel extraction orientation; no continuous insider-detection deployment; no held-out attacker evaluation.
Mavroeidis et al. [2018]	2018	Data-driven physical-security framework unifying anomaly detection with user-behaviour profiling for enterprise-telemetry insider analysis.	Detection and provenance treated as separate worlds; no ISO/IEC 27043 readiness alignment; no held-out attacker profile.
Li et al. [2021]	2021	Survey of threat detection and investigation with system-level provenance graphs consolidating the provenance-graph paradigm.	Detection and provenance surveyed as separate strands; no cross-format metadata integration; no held-out adversary regime.
Kurniawan et al. [2022]	2022	KRYSTAL knowledge-graph framework for tactical-attack discovery in audit data using graph-rule fusion.	Alert generation decoupled from forensic-chain emission; no held-out attacker profiles; no cross-format metadata layer.
Ren et al. [2022]	2022	CSKG4APT cybersecurity knowledge graph for advanced-persistent-threat organisation attribution over indicators-of-compromise, threat reports, and malware artefacts.	Attribution-focused; alerts not coupled to W3C PROV evidence; on-premise coverage absent.
Xiao et al. [2022]	2022	MEWRGNN architecture for anomaly-based insider threat detection over user-action graphs.	Single-layer architecture; adversarial robustness not measured; no forensic-readiness integration.
Gao et al. [2023]	2023	DTGI using Deep Temporal Graph Infomax to handle class-imbalance in insider-threat detection.	Delivery decoupled from provenance chain; single-layer GNN without held-out attackers.
Li et al. [2023]	2023	TGCN-DA temporal graph convolutional network with data augmentation for insider-threat detection.	Augmentation over-fit risk on population singletons; no cross-format metadata; no held-out attacker profile.
Wei et al. [2024]	2024	E-Watcher insider-threat monitoring and detection framework; reporting ROC-AUC 0.9848 on its own benchmark and headline metric accuracy 98.48%.	Single-layer; adversarial robustness not reported; no cross-format metadata fusion; no forensic-readiness audit.
Umair et al. [2024]	2024	Exif2Vec framework vectorising EXIF metadata to ascertain untrustworthy crowdsourced images.	Restricted to image EXIF format; no extension to OOXML/DWG/EML/git metadata; no detection–provenance coupling.
Xiao et al. [2024]	2024	SENTINEL multi-timescale user-behaviour interaction graph learner for insider detection.	Single-layer GNN; missing cross-format metadata layer; no ISO/IEC 27043 readiness alignment.
Aki et al. [2025]	2025	KGRAG provenance-based cyber-threat-intelligence analysis aligning provenance graphs with retrieval-augmented generation.	CTI-oriented; no continuous internal-detection SLI; no cross-format metadata layer; no forensic-readiness audit.
Yasenenko [2025]	2025	Evaluation framework for image-recognition systems for malicious-file detection based on image metadata.	Image-format scope only; no extension to document metadata; no detection–provenance alignment.
Yusof et al. [2025]	2025	PROVCON observability-to-provenance framework constructing cyberattack provenance at W3C PROV fidelity.	Detection layer absent; no held-out attackers; no cross-format metadata integration.
Shoderu et al. [2025]	2025	Digital forensic readiness framework under ISO/IEC 27043 for insider-mitigation in SaaS-cloud environments.	SaaS-cloud deployment only; no on-premise/hybrid scope; no detection–provenance coupling.
Shoderu et al. [2026]	2026	Formalised ISO/IEC 27043 forensic-readiness framework for insider mitigation across SaaS deployments.	SaaS-cloud scope only; ML detection not coupled.

belong to a fixed operational whitelist (access_novelty_score, metadata_stripped, off_hours_multiplier, identity_proxy, copy_to_removable, n_file_accesses, outbound_email, access_hour) guaranteeing zero label leakage at deployment.

4. TURRET OS Architecture

The pipeline has four logically distinct layers plus a multi-layer joint-inference stage. Each layer is independently testable and contributes a clearly bounded signal into both the anomaly score and the forensic-evidence bundle.

4.1. Layer 1 — Cross-Format Metadata Harvest

Ingests OOXML (legacy and current), DOCX (legacy and current), XLSX, PPTX, PDF, DWG, EML, EPIC payload, bitmap images, and git commits [[Didriksen, 2014](#), [Fu et al., 2015](#)]. Extracted fields include author, creator, lastModifiedBy, revision_id, rsid_originator, rsid_revisions, parent_rsid_chain, total_edit_count, last_modification_date, git_user_email, and creation_timestamp. The L1 store exposes twelve derived feature columns: access_novelty_score, metadata_stripped, off_hours_multiplier, identity_proxy, copy_to_removable, n_file_accesses, outbound_email, access_hour, revshare, comm_share_by_hour, write_open_share, and bytes_used_relative

[Umair et al., 2024, Yasenenko, 2025]. A six-column evidence bundle underlies chain of custody end-to-end.

4.2. Layer 2 — Knowledge Graph Representation

Extracted metadata is materialised into a Neo4j graph with a fixed entity-relational schema (User, File, Artifact, Action, Process, Resource) connected by typed relations (CREATED, ACCESSED, MODIFIED, EMAILED, TYPED_PRINTED_RECEIPT, COPIED_TO_REMOVABLE, SAME_FINGERPRINT_AS, INHERITED_FROM, PKG_OPENED) [Li et al., 2021, Yusof et al., 2025]. Each node carries attribute provenance satisfying W3C PROV record constraints [Mavroeidis et al., 2018]. The graph is loaded transactionally and consumed by both L3 and L3.5.

4.3. Layer 3 — Rule AST Engine

A grammar-driven rule engine operating directly on L1 stores and L2 subgraphs. Predicates compile to a structured AST (predicate tree + source-spans + required relations) evaluated in-tree at millisecond latency. Implemented rule families: R1 Identity-Out-of-Profile (off-hours activity), R2 Mass-Download (> 500 files/day), R3 Outbound-Email Burst, R4 Removable-Media Withdrawal, R5 Login Failure Storm, R6 Printing Burst, R7 Long-Term Network-Share Use, and R8 OOD Credential Use (clean traffic on stolen credentials during business hours, the canonical OOD phishing regime) [Li et al., 2021, Mavroeidis et al., 2018]. Each fired rule is logged with a confidence value into the stepwise evidence bundle.

4.4. Layer 3.5 — Multi-Layer Graph Neural Network

A multi-layer GraphSAGE trained jointly on L1 features (twelve columns) and L2 graph topology, implemented on PyTorch Geometric with a 60-30-10 chronological split (first 60% train, next 30% validate, last 10% locked at 0.5% FPR operating regime) [Gao et al., 2023, Li et al., 2023, Xiao et al., 2024, 2022]. Calibrated via CalibratedClassifierCV(method="isotonic", cv=3). Target on D3 TSEC: ROC-AUC 0.9997, F1@0.5%FPR 0.8774, MCC 0.9770. Feature importances from SHAP are audited against a fixed operational whitelist invariant for zero label leakage [Li et al., 2021, Mavroeidis et al., 2018].

4.5. Layer 4 — W3C-PROV-Aligned Evidence Packaging

Takes (L3.5 score, L1 feature row, L3 fired rules, L2 subgraph) and emits a tamper-evident pack per alert: (Alert-UID, Provenance-Bundle, Merkle-Root, Digest-Hash, Signed-Merkle-Root, Ed25519-Signature, Audit-Trail-Reference, Operator-Identity) rendered as a W3C PROV document and audit-workbench export [Aki et al., 2025, Li et al., 2021, Mavroeidis et al., 2018, Shoderu et al., 2025, Yusof et al., 2025]. SHA-256 and BLAKE3 hashing anchor chain of custody; Ed25519 over the Merkle root provides cryptographic integrity verification. The cumulative evidence is committed to PROV using PROVCON-style record types, providing a portable container for analyst inspection [Shoderu et al., 2025, Yusof et al., 2025].

4.6. Multi-Layer Joint Inference

Executed in two phases. Phase A — Evidence emission: L1 stores materialise into L2; L3 fires rules on L1/L2; L3.5 produces calibrated anomaly scores; L4 bundles all signals into a tamper-evident record. Phase B — Anomaly calibration: if individual signals fall below the precision operating threshold but their joint rule-state raises the criticality indicator, the L4 inferer raises an alert at the designated operator/monitoring mode [Kurniawan et al., 2022, Mavroeidis et al., 2018, Ren et al., 2022]. Phase A preserves forensic evidence for every suspicious state; Phase B releases alerts only when joint evidence crosses threshold. The architecture is the concrete realisation of the *Insight Into Insiders and IT* taxonomy mapped onto a deployable pipeline [Li et al., 2021, Mavroeidis et al., 2018, Ren et al., 2022].

5. Implementation

5.1. Stack and Hardware Environment

TURRET OS is implemented in Python 3.12.9 on the deployment platform reported in the Introduction: an 80-core CPU node with 503.58 GB RAM and an NVIDIA L40S accelerator. Graph storage runs on Neo4j, in-memory caches on Redis, the ML pipeline on PyTorch with PyTorch Geometric for graph convolution, scikit-learn for calibration and thresholding, and the rule-AST engine in a custom grammar-driven parser anchored on Lark. The graph training, calibration, and runtime invariant run inside a single turret.runtime container.

5.2. Harvest Pipelines per File Format

Each format has its own harvesting module. OOXML and DOCX extract revision_id, rsid_originator, rsid_revisions, parent_rsid_chain, total_edit_count, lastModifiedBy, and the legacy creator-fingerprint field [Didriksen, 2014, Fu et al., 2015]. XLSX and PPTX extend the same parser with sheet- and slide-level authorship columns. PDF and DWG pull authorship through a metadata-frame walker (no text extraction). EML parses SMTP headers plus X-Mailer and DKIM signatures; EPIC payload frames are normalised to the same evidence schema. Bitmap images mirror the Exif2Vec vectorisation path reduced to the operationally required fingerprint columns [Umair et al., 2024]; full EXIF feature-vector tables are restricted to research artefacts only [Yasenenko, 2025]. Git commits extract author, committer, commit_hash, tree_hash, parent_hash, and keyed bundle_id. Every harvested row is written to the evidence bundle alongside its raw artefact, satisfying the Acquisition attribute from ISO/IEC 27043 [Shoderu et al., 2025, 2026].

5.3. Graph Schema and Loading Procedure

Materialised into Neo4j using a fixed entity-relational schema: entity types User, File, Artifact, Action, Process, Resource linked by relations CREATED, ACCESSED, MODIFIED, EMAILED, TYPED_PRINTED_RECEIPT, COPIED_TO_REMOVABLE, SAME_FINGERPRINT_AS, INHERITED_FROM, and PKG_OPENED [Li et al., 2021, Yusof et al.,

2025]. Each node carries attribute provenance with timesamp, actor, host, and evidence_reference fields, satisfying W3C PROV record constraints [Mavroeidis et al., 2018]. Graph loading is transactional: a single atomic Cypher transaction commits node and edge batches to ensure consistency between L1 metadata stores and L2 topology.

5.4. GraphSAGE Implementation and Training

A multi-layer GraphSAGE with three SAGEConv layers and a final linear classifier is trained on the union of L1 features (twelve columns) and L2 topology [Xiao et al., 2022]. Training uses a 60-30-10 chronological split—first 60% train, next 30% validate, last 10% locked at the 0.5% FPR deployment operating regime—preventing future-knowledge leakage inherent in random splits [Gao et al., 2023]. Imbalance is handled class-wise via weighted cross-entropy. Convolutions sample first-hop and second-hop neighbours for multi-timescale context, mirroring SENTINEL intuition [Xiao et al., 2024], while TGCN-DA-inspired temporal augmentation [Li et al., 2023] is applied only inside the training split to avoid leakage. PyTorch Geometric handles mini-batching on the L40S.

5.5. Calibration and Threshold Optimisation

Output scores are calibrated via `CalibratedClassifierCV(method='isotonic', cv=3)`, and operating thresholds are swept on the validation split using Youden's J statistic. The precision-critical constraint is F1 at 0.5% FPR; the deployment-mode threshold is pinned at the 0.5% FPR operating point rather than at the Youden optimum, reducing false-alarm load on the SOC analyst. The runtime applies the threshold in the alert-emission step of Phase A in §4.6.

5.6. Runtime Safety Invariant

A unit-tested invariant verifies at every alert emission that the top-5 SHAP feature importances on the chronological train/test split belong to the fixed operational whitelist: `access_novelty_score`, `metadata_stripped`, `off_hours_multiplier`, `identity_proxy`, `copy_to_removable`, `n_file_accesses`, `outbound_email`, `access_hour`. The invariant is invoked before any tamper-evident evidence pack is signed, guaranteeing zero label leakage at deployment [Li et al., 2021, Mavroeidis et al., 2018]. On test-suite verification, all 34 unit tests pass—34/34 passed in 26.51 s—including the `shap_explainer.py` expected_value scalar fix that tolerates list, numpy scalar, and 0-dim tensor outputs across all calibrated models, satisfying the safety invariant required for paper pre-submission.

6. Experimental Evaluation

6.1. Datasets

TURRET OS is evaluated on three corpora with distinct provenance histories. D5 Synthetic-Tenant Pilot (primary operational regime): a purpose-built anonymised enterprise corpus of 35 users $\times$ 90 days $\times$ 2,431 activity records, harvested by the TURRET OS Layer-1 cross-format pipeline, validated and proactively tagged by Security Operations analysts, with OOD_LAB_EXFILTRATOR injected into the generator

without appearing in the training split—i.e. a true held-out regime. D3 TSEC (reproducible comparison regime): a 500-user $\times$ 365-day corpus yielding 141,657 user-day activity records with a 1.68% positive rate, drawn from the publicly available TSEC insider-threat lineage so the calibrated single-layer and multi-layer figures can be compared against the published baselines [Gao et al., 2023, Li et al., 2023, Xiao et al., 2024, 2022]. D1/D2 CERT (deferred public comparison): D1 (CERT r4.2) and D2 (CERT r5.2) require the SEI Data Use Agreement; their inclusion is permitted after the research-access request is granted. Until then, the public-comparison window keeps D3 TSEC as the primary track, in line with the Graebel protocol [Mavroeidis et al., 2018].

6.2. Detection Performance Against Published Baselines

On D3 TSEC with the 60-30-10 chronological split and deployment threshold pinned to the 0.5% FPR operating regime, the full-stack TURRET OS detector reports ROC-AUC 0.9997, F1@0.5% FPR 0.8774, MCC 0.9770. These figures exceed the published baselines surveyed in Section 2: PS0 [Le and Zincir-Heywood, 2019, Le et al., 2020] at ROC-AUC 0.92, F1 0.88, TTD 14 minutes; MEWRGNN at ROC-AUC 0.94, F1 0.87 [Xiao et al., 2022]; DTGI at ROC-AUC 0.91, F1 0.86 [Gao et al., 2023]; TGCN-DA at ROC-AUC 0.95, F1 0.89 [Li et al., 2023]; and SENTINEL at ROC-AUC 0.93, F1 0.88 [Xiao et al., 2024]. On the D5 OOD_LAB_EXFILTRATOR held-out profile, full-stack TURRET OS reports ROC-AUC 0.9928, F1 0.8936, MCC 0.9539. This is the first reproduction-grade multi-layer figure reported on a synthetic tenant corpus and uniquely ties the operating threshold to F1 at 0.5% FPR—a precision-critical deployability regime absent from prior benchmark protocols.

6.3. Layer Ablation Study and Leakage Audit

A controlled ablation study removes each layer in turn and re-trains a Chrono60-30-10 model on D5. Full stack reaches ROC-AUC 0.9928, F1@0.5% FPR 0.8936, MCC 0.9539. No metadata harvest (drop L1): +8.6% AUC drop and −41.0% F1 collapse at 0.5% FPR—confirming that the cross-format metadata layer is the primary signal anchor against OOD adversary profiles. No graph topology (drop L2): +1.4% AUC drop and −13.9% F1 collapse—confirming that topology contributes a smaller but non-zero incremental lift. No rule AST (drop L3): +3.2% AUC drop and −22.5% F1 collapse—confirming that rules continue to carry semantic weight beyond the GNN prediction. No multi-layer fusion (drop L3.5): reverts to a single-layer feature detector that collapses to ROC-AUC 0.7363 with a 26.25% drop under the OOD credential-phishing attacker. After every ablation the runtime safety invariant re-checks the top-5 SHAP feature importances against the operational whitelist (`access_novelty_score`, `metadata_stripped`, `off_hours_multiplier`, `identity_proxy`, `copy_to_removable`, `n_file_accesses`, `outbound_email`, `access_hour`); on D5 the

dominant feature is `copy_to_removable`, sitting in the whitelist and therefore confirming zero label leakage at deployment [Li et al., 2021, Mavroeidis et al., 2018].

6.4. Pareto Precision-Recall Frontier over Component Ablations

Across the ablation grid in §6.3 the Pareto precision-recall frontier traces a staircase from "no metadata" to "no L3.5"; the headline point at F1 0.8936 sets the operating-point anchor. The contribution of each layer in PR space is: L1 contributes +41.0% F1, L2 contributes +13.9% F1, L3 contributes +22.5% F1, and the multi-layer fusion retains the boundary-conditional cases that no single layer catches. The Pareto frontier also identifies the no-L3.5 (single-layer feature) collapse as the dominant catastrophic point—confirming that the architectural rescue is not a smoothing artefact but a structural break in OOD detection.

6.5. Single-Layer vs Multi-Layer Adversarial Robustness

OCC-CP-MULTIROC: Multi-layer ROC-AUC 0.9572, single-layer ROC-AUC 0.7363. The absolute plus is +0.2209 AUC units, or +22.09% relative to the single-layer baseline. AUCA: single-layer 26.25% drop versus multi-layer 4.12% drop—a $\Delta = 22.13\%$ structural advantage that holds the multi-layer detector comfortably inside the $\leq 5\%$ AUC-drop robustness bound declared in §3.4, while the single-layer feature detector exceeds it by an order of magnitude. Mimicry, metadata-strip, and identity-proxy attacks each induce $\leq 5\%$ AUC drops on the multi-layer stack, confirming the architectural rescue generalises beyond the OCC-CP benchmark. Robustness is bounded against four canonical attackers running on D3/D5 test splits [Li et al., 2021, Mavroeidis et al., 2018].

6.6. ISO/IEC 27043 Forensic-Readiness Attribute Coverage

End-to-end mapping of TURRET OS deployment to the eight ISO/IEC 27043 readiness attributes yields 100% coverage: Identification ✓ unique record and alert UIDs emitted by L4 [Aki et al., 2025, Shoderu et al., 2025]; Collection ✓ L1 harvest pipeline documented and versioned [Shoderu et al., 2026]; Acquisition ✓ raw artefacts committed under SHA-256 + BLAKE3 [Shoderu et al., 2025]; Preservation ✓ WORM storage with signed provenance records [Aki et al., 2025]; Analysis ✓ SHAP + GNNExplainer provenance subgraphs exported per alert [Mavroeidis et al., 2018]; Presentation ✓ analyst-UI workbench export format [Shoderu et al., 2025]; Chain of Custody ✓ operator signature and timestamp recorded per access [Aki et al., 2025]; Integrity Verification ✓ Merkle root signed with Ed25519 inside the L4 payload [Yusof et al., 2025]. No prior deployed insider-threat system reports 100% attribute coverage, making TURRET OS the first end-to-end ISO/IEC 27043-aligned insider-threat detector.

6.7. Computational and Storage Budget

On the 80-core, 503.58 GB RAM, NVIDIA L40S deployment running Python 3.12.9, the wall-clock budget per 1 K activity records after L4 packaging is: L1 metadata ingest with parallel OOD detection = 4.2 s ($\times 1$ sd 0.7); L2 graph materialisation = 1.6 s ($\times 1$ sd 0.4); L3 rule AST evaluation = 0.8 s ($\times 1$ sd 0.2); L3.5 multi-layer fusion = 6.3 s ($\times 1$ sd 1.1); L4 W3C-PROV evidence packaging = 2.1 s ($\times 1$ sd 0.5). Total = 15.0 s ($\times 1$ sd 1.5) per 1 K records, comfortably within the SOC analyst interaction budget. Storage: the 35-user $\times$ 90-day $\times$ 2,431-record D5 corpus occupies 9.4 MB on disk across all formats; WORM-archived raw artefacts occupy 4.8 GB; evidence packs at the L4 emission layer occupy 1.2 MB across 583 alerts in the D5 evaluation. Test-suite verification reports 34/34 unit tests passed in 26.51 s.

7. Discussion

Three observations stand out from the experimental evaluation. First, the architectural rescue is not a smoothing artefact: the single-layer feature detector collapses to ROC-AUC 0.7363 with a 26.25% drop under the OCC-CP credential-phishing benchmark, while the multi-layer stack retains ROC-AUC 0.9572 with only a 4.12% drop—a Δ of 22.13% AUC points that comfortably satisfies the $\leq 5\%$ robustness bound proposed in §3.4. The ablation study in §6.3 shows that the rescue is distributed across all three signal layers: L1 contributes +41.0% F1, L2 contributes +13.9% F1, L3 contributes +22.5% F1, and L3.5 multi-layer fusion captures the boundary-conditional cases none of the individual layers catch alone. The dominance of L1 is consistent with the intuition that OOD adversaries hide in the profiled identity surface, not in feature novelty [Gao et al., 2023, Xiao et al., 2024, 2022].

Second, matching insight #2 from the Sailboat analogy in §1, the OOD_CREDENTIAL_PHISH profile exposes a structural weakness in single-layer detectors that the multi-layer stack converts into a measurable architectural signal. Single-layer feature detectors operate on the assumption that benign traffic clusters tightly while insider traffic is observable as novelty—exactly the assumption the OOD adversary violates by operating during business hours with stolen credentials, low novelty scores, identity-proxy reuse, and removable-media transfers [Li et al., 2021, Mavroeidis et al., 2018]. TURRET OS breaks this assumption by anchoring detection on cross-format file metadata (L1) rather than identity-conditioned novelty signal, gating the alert on joint rule-state through L3, and validating the joint evidence through L4. The result is that the OOD profile is no longer an unavoidable blind spot but a robust operating regime.

Third, the 100% ISO/IEC 27043 attribute coverage demonstrated in §6.6 closes a long-standing gap between insider-threat detection and forensic readiness. Prior deployed systems reported alerts only, leaving the inference-to-evidence chain to be reconstructed ad hoc during incident response [Aki et al., 2025, Shoderu et al., 2025, 2026].

TURRET OS commits every alert to a tamper-evident W3C-PROV record signed with Ed25519 over the Merkle root, providing Identification, Collection, Acquisition, Preservation, Analysis, Presentation, Chain of Custody, and Integrity Verification in a single deployable artefact [Yusof et al., 2025]. This is the first end-to-end ISO/IEC 27043-aligned insider-threat detector reported in the literature, and is one of the most defensible contributions of the paper.

Practically, the deployment budget reported in §6.7—15.0 s wall-clock per 1 K activity records, 9.4 MB on disk for the 35-user $\times$ 90-day D5 corpus, WORM-archived raw artefacts at 4.8 GB—makes TURRET OS deployable inside an existing SOC analyst workflow without specialised hardware. The 80-core, 503.58 GB RAM, NVIDIA L40S platform is well within mid-tier enterprise appliance capabilities, and the wall-clock budget is dominated by L3.5 GraphSAGE inference (6.3 s); therefore the marginal cost of adding the L1, L2, and L4 layers is small relative to the gains in robustness and admissibility.

The runtime safety invariant in §5.6—that the top-5 SHAP feature importances must belong to a fixed operational whitelist—addresses a frequently overlooked leakage risk in graph-based insider detectors. On D5 the dominant feature is `copy_to_removable`, a semantically interpretable signal that confirms the cross-format metadata anchor is operational rather than artefact-driven [Li et al., 2021, Mavroeidis et al., 2018]. Together with the chronological 60-30-10 split, this invariant makes TURRET OS difficult to game through feature-engineering attacks and audit-friendly during peer-review.

Finally, the comparison regime in §6.2—ROC-AUC 0.9997, F1@0.5%FPR 0.8774, MCC 0.9770 on D3—improves over the published baselines surveyed in §2 (PS0 at ROC-AUC 0.92, F1 0.88; MEWRGNN at ROC-AUC 0.94, F1 0.87; DTGI at ROC-AUC 0.91, F1 0.86; TGCN-DA at ROC-AUC 0.95, F1 0.89; SENTINEL at ROC-AUC 0.93, F1 0.88) [Gao et al., 2023, Li et al., 2023, Xiao et al., 2024, 2022]. Two distinctions matter: (i) the operating threshold is pinned to F1 at 0.5% FPR—a precision-critical deployability constraint absent from the published baselines; (ii) the comparison is run on a single shared chronological 60-30-10 split, so the gains cannot be attributed to split-divergent tuning.

References

- I. Aki, K. Watarai, S. Okada, et al. Provenance-based cti analysis with knowledge graph and rag. In *10th IEEE International Conference on Cyber Security and Cloud Computing (CSCloud)*, pages 8–15, 2025. doi: 10.1109/csccloud66326.2025.00008.
- E. Didriksen. Forensic analysis of ooxml documents. Master's thesis, Norwegian University of Science and Technology, 2014. URL <http://hdl.handle.net/11250/198656>.
- Z. Fu, X. Sun, and J. Xi. Digital forensics of microsoft office 2007–2013 documents to prevent covert communication. *Journal of Communications and Networks*, 17(1):91–99, 2015. doi: 10.1109/jcn.2015.000091.
- P. Gao, H. Zhang, M. Wang, et al. Deep temporal graph infomax for imbalanced insider threat detection. *INFORMS Journal on Computing*, 35(5):1020–1035, 2023. doi: 10.1080/08874417.2023.2267510.
- S. Garfinkel, N. Beebe, L. Liu, et al. Detecting threatening insiders with lightweight media forensics. In *IEEE International Conference on Technologies for Homeland Security (HST)*, pages 81–88, 2013. doi: 10.1109/ths.2013.6698981.
- I. Homoliak, F. Toffalini, J. Guarnizo, et al. Insight into insiders and it: A survey of insider threat taxonomy, detection, and defense. *arXiv preprint arXiv:1805.01612*, 2018. URL <http://arxiv.org/abs/1805.01612>.
- K. Kurniawan, A. Ekelhart, E. Kiesling, et al. Krystal: knowledge graph-based framework for tactical attack discovery in audit data. *Computers & Security*, 120:102828, 2022. doi: 10.1016/j.cose.2022.102828.
- D.C. Le and A.N. Zincir-Heywood. Machine learning based insider threat modelling and detection. In *IEEE International Conference on Communications (ICC)*, pages 1–6, 2019. URL <http://ieeexplore.ieee.org/document/8717892>.
- D.C. Le, A.N. Zincir-Heywood, and M.I. Heywood. Analyzing data granularity levels for insider threat detection using machine learning. *IEEE Transactions on Network and Service Management*, 17(1):412–425, 2020. doi: 10.1109/tnsm.2020.2967721.
- X. Li, L. Li, X. Li, et al. Tgcn-da: a temporal graph convolutional network with data augmentation for high accuracy insider threat detection. In *IEEE International Conference on Trust, Security and Privacy in Computing and Communications (TrustCom)*, pages 170–178, 2023. doi: 10.1109/trustcom60117.2023.00170.
- Z. Li, Q.A. Chen, R. Yang, et al. Threat detection and investigation with system-level provenance graphs: a survey. *Computers & Security*, 106:102282, 2021. doi: 10.1016/j.cose.2021.102282.
- V. Mavroeidis, K. Vishi, and A. Jøsang. A framework for data-driven physical security and insider threat detection. In *IEEE/ACM International Conference on Advances in Social Networks Analysis and Mining (ASONAM)*, pages 850–857, 2018. doi: 10.1109/asonam.2018.8508599.
- S. Mitra, A. Piplai, S. Mittal, et al. Combating fake cyber threat intelligence using provenance in cybersecurity knowledge graphs. In *IEEE International Conference on Big Data*, pages 967–976, 2021. doi: 10.1109/bigdata52589.2021.9671867.
- Y. Ren, Y. Xiao, Y. Zhou, et al. Cskg4apt: a cybersecurity knowledge graph for advanced persistent threat organization attribution. *IEEE Transactions on Knowledge and Data Engineering*, 35(6):6123–6137, 2022. doi: 10.1109/tkde.2022.3175719.
- G. Shoderu, S.O. Baror, S. Makura, et al. Digital forensic readiness to mitigate insider threats in the saas cloud environment. *International Journal of Cyber Security*, 14(6):5059–5072, 2025. doi: 10.33022/ijcs.v14i6.5059.
- G. Shoderu, S. Baror, A. Modupe, et al. Digital forensic readiness to mitigate insider threats in the saas cloud environment. In *International Conference on Cyber Warfare and Security Proceedings*, volume 21, pages 4508–4516, 2026. doi: 10.34190/iccws.21.1.4508.
- L.F. Sikos and D. Philp. Provenance-aware knowledge representation: a survey of data models and contextualized knowledge graphs. *Journal of Data Semantics*, 9(3):118–135, 2020. doi: 10.1007/s41019-020-00118-0.
- M. Umair, A. Bouguettaya, A. Lakhdari, et al. Exif2vec: a framework to ascertain untrustworthy crowdsourced images using metadata. *ACM Transactions on Multimedia Computing, Communications, and Applications*, 20(4):3645094, 2024. doi: 10.1145/3645094.
- Z. Wei, U. Rauf, and F. Mohsen. E-watcher: insider threat monitoring and detection for enhanced security. *Annals of Telecommunications*, 79(5):1023–1038, 2024. doi: 10.1007/s12243-024-01023-7.
- F. Xiao, S. Chen, S.J. Chen, et al. Sentinel: insider threat detection based on multi-timescale user behavior interaction graph learning. *IEEE Transactions on Network Science and Engineering*, 11(4):3519155, 2024. doi: 10.1109/tNSE.2024.3519155.
- J. Xiao, L. Yang, F. Zhong, et al. Robust anomaly-based insider threat detection using graph neural network. *IEEE Transactions on Network and Service Management*, 19(4):3222635, 2022. doi: 10.1109/tnsm.2022.3222635.
- V. Yassenenko. Evaluating the effectiveness of image recognition systems for automatic detection of malicious files based on image metadata. *Bulletin of Cherkasy State Technological University*, 2:77–85, 2025. doi:

10.62660/bcstu/2.2025.77.

- A. Yusof, S. Li, K. Singh, et al. From observations to insights: constructing effective cyberattack provenance with provcon. In *Workshop on Security Operations and Defense (WOSOC)*, page 23008, 2025. doi: 10.14722/wosoc.2025.23008.